



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



XMRig miner; packed Windows PE variant Malware Analysis

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | XMRig miner; packed Windows PE variant Malware Analysis - Malware Analysis Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

XMRig Malware Analysis

1. Executive Summary

Lost Boys Cyber assesses the submitted Windows x64 PE sample as an XMRig cryptominer payload or XMRig-packed miner delivery component with high confidence. The family assessment is based on external sandbox/OSINT correlation that labels the exact SHA256 as xmrigh, miner, evasion, and upx, and on local static evidence showing a high-entropy packed PE with anti-analysis indicators. The local TRASHcan run was less conclusive dynamically because guest process telemetry was not collected, but it did produce corroborating evidence of a user-writable autorun persistence condition, packet capture coverage, and static packer/anti-VM indicators.

Key Finding	Evidence	Defensive Implication	Confidence
Exact sample is associated with XMRig miner activity	Triage public report for SHA256 af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572 labels the sample xmrigh, miner, evasion, upx and shows memory YARA hits for xmrigh	Treat any host execution as unauthorized cryptomining and credential/infrastructure exposure until containment is complete	High
Packed/obfuscated x64 PE	9.4 MB PE32+ GUI executable, unusual section names, file entropy 7.965, one high-entropy executable raw section . Q4, sparse import table	Static controls should hunt for both the submitted hash and behavioral miner/evasion traits, not only cleartext strings	High
Anti-analysis indicators are present	capa detects analysis-tool string references and Xen anti-VM strings; .tls section present; Triage tags evasion	Detonation may be incomplete in lab VMs; prioritize memory capture and endpoint telemetry if seen in production	Medium-High
Local dynamic telemetry was limited	TRASHcan summary shows process_tree empty and Sysmon process/file/registry sample counts of 0 despite guest artifacts and PCAP collection	The local run should be treated as partial coverage; do not over-interpret the lack of observed process/network C2	High
Autorun persistence condition was observed	TRASHcan behavior flags HKCU Run OneDrive pointing to user-writable AppData path	Investigate per-user Run/RunOnce values and validate whether OneDrive path was abused or baseline in affected hosts	Medium

The sample should be handled as malicious. Recommended immediate actions are to quarantine the binary by SHA256, search for execution from user-writable paths, hunt for XMRig memory/file signatures, review endpoint process trees for miner-like child execution and service tampering, and block/monitor known mining-pool traffic associated with public reporting for this sample.

2. Sample Metadata

Field	Value
Report Title	XMRig Malware Analysis
Malware family / cluster	XMRig miner; packed Windows PE variant

Sample count	1 uploaded archive containing 1 executable
Submitted archive	/home/lost0x01/internal-secops-portal/data/uploads/20260617_183712_464370/af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572.7z
Archive password	infected
Extracted filename in analysis workspace	sample.exe
SHA256	af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572
SHA1	b6c4a743c2fa8ed7fca8257d26134806b64ef9e0
MD5	5807efef92e20ffe074bbdc141cfbdad
Size	9,899,008 bytes
File type	PE32+ executable (GUI), x86-64, Windows, stripped to external PDB, 14 sections
Compilation timestamp from PE metadata	2023-01-21 15:03:14 UTC-like PE timestamp; treat as attacker-controlled/low-confidence
Authenticode status	Not signed in local static triage
Subsystem	Windows GUI
Local sandbox run	/home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a
TRASHcan verdict	suspicious; score 55; confidence 0.55
Public OSINT correlation	MalwareBazaar search result and Triage public report identify this sample as XMRig/miner; MalwareBazaar result also references pool.hashvault.pro and 45.76.89.70

3. Source Review & Confidence

Source	What Was Used	Reliability	Notes
Submitted archive	Extracted and hashed locally with 7z and sha256sum	High	Archive contained one PE matching the task hash.
TRASHcan static_triage.json	PE metadata, imports, section layout, initial IOC extraction	High	Direct local artifact for the submitted sample.
TRASHcan analysis.md / summary.json / behavior_summary.json	Sandbox verdict, autorun finding, network capture summary, telemetry limitations	Medium	Guest artifacts exist, but process tree and Sysmon event collections are empty.
capa / FLOSS / radare2 local analysis	Capabilities, string recovery, entrypoint disassembly, entropy	Medium-High	Useful for packer/anti-analysis assessment; not a full

	and section review		unpacked-code recovery.
GhidraMCP	Attempted via available MCP tool	Low for this run	MCP endpoint returned an OpenCTI HTML page instead of Ghidra function data, so Ghidra-backed decompilation was unavailable. radare2/capa were used as fallback reversing evidence.
Triage public report 230222-bpdrpabb9s	Exact SHA256 page, labels, signatures, memory-YARA references	Medium-High	Public sandbox page associates the exact sample with xmrigh, miner, evasion, upx and XMRig memory hits.
MalwareBazaar search result	Exact SHA256 listing snippets	Medium	Browser/API access was blocked or unauthorized; search snippets still correlated the hash with malware and mining-pool infrastructure.
Gridinsoft XMRig threat profile	Family-level context	Medium	Used only for general XMRig behavior context, not as sample-specific proof.

Analyst confidence: High that the sample belongs to the XMRig miner family or an XMRig-packed miner delivery cluster. Confidence is lower for exact local execution chain, persistence write attribution, and mining-pool configuration because local dynamic telemetry did not capture process lineage or decoded runtime configuration.

4. Initial Triage and Delivery Assessment

The submitted artifact is a password-protected 7z archive containing one Windows x64 executable. Password-protected archives are common in malware submissions and commodity delivery chains because they bypass some mail/web scanners and preserve the sample for controlled analysis. The extracted executable is unusually large for a simple loader and contains sparse imports with a high-entropy executable section, both of which are consistent with packing or payload embedding.

Triage Signal	Observation	Assessment
Archive container	7z, AES-encrypted, password infected	Consistent with analyst submission and common malware exchange handling.
PE class	PE32+ x86-64 GUI executable	Native Windows payload, not .NET.
Import table	CreateSemaphoreW, GetVersion, CharUpperBuffW, LocalAlloc/LocalFree, GetModuleFileNameW, LoadLibraryA, GetModuleHandleA, GetProcAddress, ExitProcess, __C_specific_handler	Sparse import set suggests dynamic API resolution and/or packed code.
Section layout	14 sections; virtual-only standard-looking sections; high-entropy raw executable section named . Q4	Strong packer/obfuscation signal.
Entrypoint	0x140bb5452 inside high-entropy . Q4 section	Entrypoint in packed section rather than normal .text increases confidence in packed payload.
Static strings	Mostly random-looking short strings; few	Consistent with compression/encryption

	meaningful configuration strings recovered by FLOSS	and string obfuscation.
Public sandbox labels	xmrig, miner, evasion, upx	Supports XMRig family classification.

The delivery vector was not present in the evidence bundle. Treat the sample as a standalone payload recovered from an external source or host, not as proof of a specific phishing, exploit, or drive-by chain.

5.1 PE Structure and Packer Assessment

The binary has an overall Shannon entropy of 7.965, which is near the practical maximum for random/compressed/encrypted data. The raw section .Q4 is 0x96f800 bytes with entropy 7.966 and has executable permissions. Several preceding sections have virtual size but zero raw size, and the section names include nonstandard values such as .%,R, .-dx, and .Q4.

Section	Virtual Address	Virtual Size	Raw Offset / Raw Size	Entropy	Analyst Note
.text	0x00001000	0xb048	0x0 / 0x0	0.000	Virtual-only; atypical for a normal PE code section.
.data	0x0000d000	0x37d6e0	0x0 / 0x0	0.000	Large virtual data region without raw bytes.
.,R	0x00392000	0x37edd6	0x0 / 0x0	0.000	Nonstandard name; likely unpacking target or reserved memory.
.-dx	0x00711000	0x8c0	0x400 / 0xa00	0.153	Contains import/IAT-adjacent data.
.Q4	0x00712000	0x96f6b0	0xe00 / 0x96f800	7.966	Main packed/high-entropy executable payload region; entrypoint lands here.
.reloc	0x01082000	0xd8	0x970600 / 0x200	2.078	Relocation data present but PE metadata reports relocs false.
.rsrc	0x01083000	0x388	0x970800 / 0x400	5.024	Small resource area.

Public sandbox reporting tagged the sample as upx. The on-disk section names are not ordinary UPX0/UPX1 labels, so this should be described as packed or modified-UPX-like rather than cleanly recoverable with a default UPX unpack command without further validation.

5.2 Hashes and File Identity

Hash Type	Value
MD5	5807efef92e20ffe074bbdc141cfbdad
SHA1	b6c4a743c2fa8ed7fca8257d26134806b64ef9e0

SHA256	af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572
--------	--

5.3 Imports and Loader Clues

KERNEL32.dll!CreateSemaphoreW msvcrt.dll!__C_specific_handler KERNEL32.dll!GetVersion USER32.dll!CharUpperBuffW KERNEL32.dll!LocalAlloc KERNEL32.dll!LocalFree KERNEL32.dll!GetModuleFileNameW KERNEL32.dll!ExitProcess KERNEL32.dll!LoadLibraryA KERNEL32.dll!GetModuleHandleA KERNEL32.dll!GetProcAddress

The import list is too small for a full miner implementation, which normally needs threading, networking, cryptographic/hash routines, and system discovery. The observed imports are more consistent with a packed stub that resolves additional APIs dynamically after unpacking. CreateSemaphoreW may be used for singleton execution; LoadLibraryA/GetProcAddress are common in unpackers and loaders; GetVersion and CharUpperBuffW are often seen in compatibility checks, environment checks, or obfuscated import reconstruction.

5.4 Static IOC Extraction Quality

The automatic static IOC extractor produced many domain-like strings such as 0.WmDk, 8qNlj.uziV, and h.reloc. These are assessed as false-positive artifacts from high-entropy packed data and section names, not actionable domains. No hardcoded public IP, URL, registry key, or meaningful Windows path was recovered from the local static artifact set.

6.1 Reversing Tooling and Limitations

GhidraMCP was attempted as required for executable code, but the MCP response returned an OpenCTI HTML page instead of a Ghidra function listing. Because the GhidraMCP path was not usable in this run, code-level evidence was collected through radare2, rabin2, capa, FLOSS, and PE parsing. This is sufficient for packer and capability assessment but not for a fully unpacked control-flow reconstruction.

Code Evidence	Result	Interpretation
Entrypoint	0x140bb5452, raw offset 0x4a4252	Entrypoint lies in the packed . Q4 section.
radare2 entry disassembly	call fcn.1407eacee; followed by invalid/garbled bytes	Likely packed stub or radare2 disassembly confusion over encrypted/compressed code.
capa capabilities	anti-analysis strings; anti-VM Xen string; TLS section	Anti-analysis and VM-awareness indicators.
FLOSS output	Mostly random printable fragments; no clear miner config recovered	Strings likely encrypted/compressed or only recovered after runtime unpacking.
Imports	Sparse LoadLibrary/GetProcAddress-centric import set	Dynamic API resolution likely.

6.2 Entrypoint Snippet

; radare2 at entry0		
0x140bb5452	e89758c3ff	call fcn.1407eacee
0x140bb5457	3057b6	xor byte [rdi - 0x4a], dl
0x140bb545a	37	invalid

The short entrypoint block, invalid byte after an apparent call, and entrypoint placement inside a large high-entropy section are consistent with obfuscated transfer into an unpacking routine or analysis-resistant code layout. This finding supports the packer assessment but does not by itself recover the mining configuration.

6.3 capa Findings

capa identified the following relevant capabilities:

Capability	Namespace / Mapping	Evidence
Reference analysis tools strings	anti-analysis; MBC Discovery::Analysis Tool Discovery::Process detection B0013.001	String pattern for ida at file offset 0x31EEAF.
Reference anti-VM strings targeting Xen	anti-analysis/anti-vm/vm-detection; ATT&CK T1497.001	String pattern Xen at file offset 0x778862.
Contains a TLS section	executable/pe/section/tls	.tls section at VA 0x140391000.

The capa result does not expose mining logic directly because the sample appears packed. The public Triage report bridges this gap by reporting XMRig memory YARA hits after execution.

6.4 Family Assessment

The family is assessed as XMRig based on exact-hash public sandbox labeling and memory detection rather than local cleartext configuration recovery. Public Triage content for this hash reports:

- Family/tag labels: xmrig, miner, evasion, upx.
- Signature: xmrig — XMRig is a high performance, open source, cross platform CPU/GPU miner.
- Signature: XMRig Miner payload, with many memory dump resources matching YARA rule xmrig.
- Additional behaviors: modifies security service, suspicious use of NtCreateUserProcessOtherParentProcess, stops running services, deletes itself, executes dropped EXE, loads dropped DLL, scheduled-task related behavior, process enumeration, LoadsDriver, AdjustPrivilegeToken, WriteProcessMemory.

Because this exact sample is packed and the local run did not recover a runtime configuration, do not assume the public pool/wallet configuration remained unchanged in any derivative sample unless memory or network telemetry from the affected environment confirms it.

7. Dynamic Analysis

TRASHcan detonated the sample in win-malware-lab and restored the clean-guestadditions-sysmon snapshot after the run. The run produced a PCAP and guest artifacts, but local process and Sysmon telemetry were sparse.

Dynamic Evidence	Observation	Assessment
Sandbox duration	536.49 seconds total across the sample run	Sufficient wall-clock for basic execution, but telemetry gaps remain.
Guest artifacts	present	Collection succeeded at least partially.
Process tree	empty	Execution lineage not captured; do not infer no execution.
Sysmon process events	0 sample events in summary	Sysmon collection failed, was not populated, or did not parse into summary.
Dropped files	summary dropped_files list empty	No sample-attributed dropped files in local summary.
Registry events	0 Sysmon registry events, but autorun collection showed values	Autorun inventory exists; event-level write attribution absent.
Network capture	2,215 packets, 393 kB PCAP, 234.15	Network baseline captured; no suspicious

	seconds	local C2 was confirmed.
Suricata alerts	0	No local IDS alert during TRASHcan run.

7.1 Local Behavioral Finding

TRASHcan flagged one high-severity persistence behavior:

Type	Technique	Evidence	Analyst Assessment
Persistence	T1060 / T1547.001	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\OneDrive -> "C:\Users\analyst\AppData\Local\Microsoft\OneDrive\OneDrive.exe" /background	This path is user-writable and persistence-relevant. Because OneDrive is common baseline software and event-level attribution is absent, treat this as a triage lead requiring endpoint validation rather than definitive sample-created persistence.

7.2 Public Dynamic Correlation

Public Triage analysis of the exact hash produced stronger dynamic findings than the local run, including XMRig memory detections, service/security modification, service stopping, self-deletion, dropped EXE/DLL activity, scheduled task indicators, process enumeration, driver loading, privilege adjustment, and WriteProcessMemory. These are consistent with commodity miner deployment tradecraft: evade security controls, persist or relaunch, deploy/execute mining payload, and inject or unpack miner code in memory.

8. Process Tree and Execution Chain

The local TRASHcan process_tree field is empty and no Sysmon process events were parsed. Therefore, the exact local parent/child execution chain cannot be reconstructed from the available TRASHcan artifacts.

Working execution hypothesis, clearly separated from observation:

- 1. Packed x64 PE starts from entrypoint 0x140bb5452 in high-entropy section . Q4.
- 2. Stub resolves APIs dynamically through LoadLibraryA/GetProcAddress.

3. Stub unpacks or maps XMRig miner code into memory.

- 4. Payload performs anti-analysis/environment checks and may alter security service state.
- 5. Payload starts miner worker logic and/or executes/drops additional components.
- 6. Payload may persist via scheduled task or Run key depending on environment.

This hypothesis is supported by public Triage signatures and local static packer indicators, but local telemetry did not capture the process lineage needed to confirm each step in this environment.

9. Persistence and System Modification

Mechanism	Evidence	ATT&CK	Confidence	Defensive Action
HKCU Run autorun to user-writable path	OneDrive value under HKCU Run points to AppData Local OneDrive.exe /background	T1547.001	Medium	Audit Run/RunOnce keys across affected hosts; verify signer/hash/path of OneDrive.exe.
Scheduled task usage	Public Triage reports Creates scheduled task(s) and Task	T1053	Medium	Search Security/TaskScheduler/Sysmon for new tasks

	Scheduler COM API usage			created around execution time.
Security service registry modification	Public Triage reports Modifies security service and maps to T1112/T1031	T1112, T1562-adjacent	Medium-High	Review service registry changes, security product tamper logs, and Windows Defender operational events.
Service stopping	Public Triage reports Stops running service(s)	T1489 / T1562	Medium	Hunt for sc.exe, net stop, ControlService API patterns, and service-control events.
Self-deletion	Public Triage reports Deletes itself	Defense evasion	Medium	Search for process execution followed by file delete/rename in user-writable paths.

Local evidence is strongest for the existence of a persistence-relevant Run key value and weakest for the exact write operation. Public sandbox evidence supports broader miner evasion and persistence behavior.

10. Network and Infrastructure Analysis

The local PCAP contained 2,215 packets over 234.15 seconds with common Windows/Microsoft background traffic. No local suspicious domains, suspicious HTTP events, suspicious HTTP requests, Suricata alerts, or Sysmon DNS events were reported by TRASHcan. Observed DNS/TLS artifacts included Microsoft and Windows baseline names such as www.msftconnecttest.com, ctldl.windowsupdate.com, edge.microsoft.com, nav.smartscreen.microsoft.com, settings-win.data.microsoft.com, v20.events.data.microsoft.com, and www.bing.com.

Network Signal	Local Observation	Assessment
DNS queries	33 queries, largely Windows baseline and local/mDNS/LLMNR names	No local C2/mining-pool query confirmed.
TLS SNI	Microsoft/Edge/Windows names only	No local malicious SNI confirmed.
HTTP requests	110 HTTP requests, examples include msftconnecttest and Windows certificate/update endpoints	Baseline OS/application traffic.
Suricata alerts	0	No IDS-confirmed malicious traffic in local run.
Public OSINT	MalwareBazaar search result references pool.hashvault.pro and 45.76.89.70:49695/80 for this hash	Treat as sample-associated OSINT requiring validation in environment telemetry.

Miner payloads frequently contact mining pools over TCP, HTTP, TLS, or Stratum-like protocols and may delay or suppress network activity in VMs. The absence of local mining-pool traffic should not be considered exculpatory due to the anti-analysis indicators and process telemetry gaps.

11.1 High-Confidence File Indicators

Type	Value	Context
SHA256	af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572	Submitted sample; exact hash publicly associated with XMRig/miner activity.

SHA1	b6c4a743c2fa8ed7fca8257d26134806b64ef9e0	Submitted sample.
MD5	5807efef92e20ffe074bbdc141cfbdad	Submitted sample; found in public XMRig threat listings/search results.
Filename	af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572.exe	Public Triage sample naming.
File characteristic	x64 PE, high entropy 7.965, entrypoint in high-entropy executable . Q4 section	Hunt for similar packed variants, not just exact hash.

11.2 Persistence / Host Indicators

Type	Value	Confidence	Notes
Registry Run key	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\OneDrive	Medium	Local TRASHcan flagged user-writable autorun path; validate signer/hash of target.
Autorun target	C:\Users\analyst\AppData\Local\Microsoft\OneDrive\OneDrive.exe /background	Medium	Could be legitimate OneDrive in the sandbox; suspicious when created/modified near sample execution or unsigned/mismatched.
Scheduled tasks	New or modified scheduled tasks after execution	Medium	Based on public Triage, not local artifact.
Service tampering	Security service registry modification or service stop events	Medium-High	Based on public Triage.

11.3 Network Indicators

Type	Value	Confidence	Notes
Domain	pool.hashvault.pro	Medium	MalwareBazaar search snippet associated this hash with the mining pool; not observed locally.
IP/port	45.76.89.70:49695	Medium	MalwareBazaar search snippet associated this endpoint with the sample.
IP/port	45.76.89.70:80	Medium	MalwareBazaar search snippet associated this endpoint with the sample.

Do not block shared mining-pool domains or VPS IPs without considering operational impact and recency. Use these as hunt pivots and enrichment points first.

12. MITRE ATT&CK Mapping

Technique	Name	Evidence	Confidence
T1497.001	Virtualization/Sandbox	capa anti-VM Xen string and	Medium-High

	Evasion: System Checks	public evasion tag	
T1027	Obfuscated/Compressed Files and Information	High entropy, packed section, sparse imports, public upx tag	High
T1059 / dynamic execution support	Command and scripting not directly observed	Not confirmed locally; omit from priority detection unless endpoint telemetry shows script launch	Low
T1055	Process Injection	Public Triage reports WriteProcessMemory and suspicious parent process creation	Medium
T1053	Scheduled Task/Job	Public Triage reports scheduled task and Task Scheduler COM API	Medium
T1112	Modify Registry	Public Triage security service registry modification; local autorun inventory finding	Medium
T1489	Service Stop	Public Triage reports Stops running service(s)	Medium
T1547.001	Registry Run Keys / Startup Folder	TRASHcan autorun persistence finding	Medium
T1562	Impair Defenses	Public Triage service/security modification and service stop behavior	Medium-High
T1496	Resource Hijacking	XMRig miner family classification and public XMRig payload signature	High
T1071	Application Layer Protocol	Potential mining-pool communication based on MalwareBazaar snippet; no local C2 observed	Medium-Low

13.1 YARA: Packed XMRig Candidate / Exact Sample

```
rule LBC_XMRig_Packed_PE_af421881
{
  meta:
    description = "Detects the submitted packed XMRig-associated PE by hash and high-level PE traits"
    author = "Lost Boys Cyber"
    date = "2026-06-17"
    sha256 = "af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572"
    family = "XMRig"
    tlp = "TLP:CLEAR"
  strings:
    $mz = { 4D 5A }
    $s1 = "LoadLibraryA" ascii wide
    $s2 = "GetProcAddress" ascii wide
    $s3 = "CreateSemaphoreW" ascii wide
    $sec1 = ". Q4" ascii
}
```

```

$sec2 = ".%,R" ascii
$sec3 = ".-dx" ascii
condition:
  uint16(0) == 0x5A4D and
  filesize > 9MB and filesize < 10MB and
  all of ($s*) and 2 of ($sec*)
}

```

13.2 Sigma: User-Writable Run Key Persistence

```

title: User Writable Run Key Persistence for Miner-Like Payload
id: 6742b0b2-d5d2-5d99-8a07-2ba84ad15e4a
status: experimental
description: Detects Run or RunOnce persistence pointing at user-writable paths, adapted from the
TRASHcan-generated behavior rule for af421881.
references:
  - local-sandbox-run:af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572
author: Lost Boys Cyber / RAIconoon local sandbox
date: 2026-06-17
tags:
  - attack.persistence
  - attack.t1547.001
logsource:
  product: windows
  service: sysmon
detection:
  selection_event:
    EventID:
      - 12
      - 13
      - 14
    TargetObject|contains:
      - '\Run'
      - '\RunOnce'
      - '\StartupApproved'
  selection_path:
    Details|contains:
      - '\Temp\'
      - '\AppData\'
      - '\ProgramData\'
      - '\Startup\'
  condition: selection_event and selection_path
falsepositives:
  - Legitimate software updaters using per-user autoruns
  - Legitimate OneDrive per-user autorun; validate signer, hash, creation time, and parent process
level: high

```

13.3 Microsoft Defender XDR / KQL

```

let SampleHashes = dynamic([
  "af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572",
  "b6c4a743c2fa8ed7fca8257d26134806b64ef9e0",
  "5807efef92e20ffe074bbdc141cfbdad"
]);
DeviceFileEvents
| where SHA256 in (SampleHashes) or SHA1 in (SampleHashes) or MD5 in (SampleHashes)
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, SHA256, SHA1, MD5,
InitiatingProcessFileName, InitiatingProcessCommandLine, InitiatingProcessAccountName
DeviceRegistryEvents
| where RegistryKey has_any (@"\Software\Microsoft\Windows\CurrentVersion\Run",
@"\Software\Microsoft\Windows\CurrentVersion\RunOnce")
| where RegistryValueData has_any (@"\AppData", @"\Temp", @"\ProgramData", @"\Startup")
| project Timestamp, DeviceName, ActionType, RegistryKey, RegistryValueName, RegistryValueData,
InitiatingProcessFileName, InitiatingProcessCommandLine, InitiatingProcessSHA256
DeviceNetworkEvents
| where RemoteUrl =~ "pool.hashvault.pro" or RemoteIP == "45.76.89.70" or RemotePort in (49695, 80)
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine,

```

```
InitiatingProcessSHA256, RemoteUrl, RemoteIP, RemotePort, Protocol
DeviceProcessEvents
| where ProcessCommandLine has_any ("xmrig", "stratum+tcp", "pool.hashvault.pro", "--donate-level", "--coin", "--algo")
  or FileName in~ ("xmrig.exe", "xmr-stak.exe")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, SHA256, InitiatingProcessFileName, InitiatingProcessCommandLine, AccountName
```

13.4 Splunk SPL

```
index=wineventlog (source="WinEventLog:Microsoft-Windows-Sysmon/Operational" OR
source="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational")
(EventCode=1 OR EventCode=11 OR EventCode=13 OR EventCode=22)
("af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572" OR
"5807efef92e20ffe074bbdc141cfbdad" OR "pool.hashvault.pro" OR "45.76.89.70" OR "stratum+tcp" OR
"xmrig")
| table _time host EventCode Image CommandLine TargetFilename TargetObject Details DestinationHostname
DestinationIp DestinationPort Hashes ParentImage ParentCommandLine User
```

14. Threat Hunting

Hunt	Hypothesis	Primary Data	Expected Signal
Exact hash sweep	The submitted sample or same archive payload exists on endpoints	EDR file inventory, proxy downloads, email attachments	SHA256/SHA1/MD5 match, especially in Downloads, Temp, AppData, ProgramData.
Packed miner variants	Related variants use similar packed PE structure but different hashes	File metadata, entropy, import table, section names	x64 PE around 9-10 MB, very high entropy, sparse imports LoadLibraryA/GetProcAddress, unusual sections .Q4/./R/./dx.
User-writable autoruns	Miner or loader established per-user startup persistence	Registry telemetry	Run/RunOnce values pointing to AppData, Temp, ProgramData, Startup, especially unsigned binaries.
Service/security tampering	Payload attempted to impair defenses before mining	Windows service control, Defender, EDR tamper logs	Service stop/config changes, Defender exclusions, SecurityHealth/WinDefend modifications near suspicious process execution.
Mining-pool beaconing	Runtime miner contacted public pool infrastructure	DNS, proxy, firewall, Zeek, EDR network	pool.hashvault.pro, 45.76.89.70, Stratum-like traffic, long-lived outbound sessions from workstations/servers.
CPU resource hijacking	Hosts exhibit miner execution even without known hash	EDR performance, process telemetry, command lines	Sustained high CPU, miner-like process arguments, unknown unsigned binary in user-writable path.

Example Zeek/SQL-style hunt logic:

```
-- Pseudocode for network lake / Zeek conn + dns logs
SELECT ts, uid, id_orig_h, id_resp_h, id_resp_p, proto, service, duration, orig_bytes, resp_bytes
FROM conn
WHERE id_resp_h = '45.76.89.70'
  OR id_resp_p IN (3333, 4444, 5555, 7777, 14444, 49695)
```

```
OR uid IN (
    SELECT uid FROM dns WHERE query = 'pool.hashvault.pro' OR query LIKE '%.hashvault.pro'
);
```

15. Triage and Incident Response

- 1. Quarantine and collect the binary, parent archive, and surrounding directory contents from any matching host.
- 2. Capture volatile telemetry before reboot when possible: process list, loaded modules, network connections, scheduled tasks, autoruns, security product state, and memory if feasible.
- 3. Search for the exact hashes across EDR, email, proxy, web download, and file-share telemetry.
- 4. Review process lineage around first-seen time, especially execution from user-writable directories.
- 5. Check Run/RunOnce keys, Startup folders, scheduled tasks, services, Defender exclusions, and security service configuration changes.
- 6. Hunt for mining pool communication and sustained high CPU usage from unsigned or unknown processes.
- 7. Reset credentials used interactively or by services on affected hosts if post-exploitation or lateral movement cannot be excluded.
- 8. Reimage or clean systems where miner persistence, service tampering, or injected miner code is confirmed; commodity miners are frequently bundled with access brokers or additional payloads.

Priority	Action	Owner	Success Criteria
P0	Block/quarantine exact hash and submitted archive	EDR/SOC	Hash cannot execute and historical hits are enumerated.
P0	Sweep endpoint and network telemetry for IOC set	SOC	All hosts with file/network/registry matches are identified.
P1	Validate autoruns and scheduled tasks on matched hosts	IR	Persistence removed or confirmed benign with signer/hash evidence.
P1	Review security-control tampering	IR/Endpoint Engineering	Defender/EDR service state and exclusions restored.
P2	Add miner behavior detections	Detection Engineering	KQL/Sigma/YARA coverage deployed with false-positive notes.

16. Validation and Emulation

Recommended validation steps for defenders:

Validation	Method	Expected Outcome
Hash detection	Place the SHA256 in an isolated test path and verify EDR/file IOC rule match without execution	Alert on exact sample hash.
YARA static detection	Scan the submitted PE and benign software corpus with LBC_XMRig_Packed_PE_af421881	Match submitted sample; review false positives among packed installers.
Autorun detection	Create a benign test Run key pointing to a controlled AppData executable path	Sigma/KQL rules alert; documented OneDrive/updater exceptions are manageable.
Network hunt	Replay or simulate DNS for	Network queries return expected events

	pool.hashvault.pro and connection metadata to 45.76.89.70:49695 in a lab log source	without requiring malicious execution.
Service tamper detection	In a lab, stop a noncritical test service using approved tools and verify service stop telemetry	Service stop hunts populate; tune to avoid admin maintenance windows.

Do not execute the submitted malware in production. If deeper reverse engineering is required, rerun in a controlled sandbox with memory dumping and working Ghidra/GhidraMCP connectivity, then attempt unpacking around entrypoint 0x140bb5452 and the . Q4 section.

17. Recommendations

Recommendation	Priority	Rationale
Deploy exact-hash block for SHA256 af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572	High	Prevents known submitted payload execution while broader detections are tuned.
Hunt for miner and mining-pool activity across the last 30-90 days	High	XMRig infections may persist quietly and signal initial access or weak controls.
Alert on user-writable Run/RunOnce persistence with signer/hash enrichment	High	Covers this sample's local persistence lead and many commodity loaders.
Monitor security service modification and service stops from untrusted processes	High	Public dynamic reporting indicates defense-evasion behavior.
Add packed-PE triage rules to malware intake	Medium	High-entropy/sparse-import samples require unpacking/memory-first workflows.
Improve sandbox telemetry collection	Medium	Ensure Sysmon process, registry, file, and DNS events are collected and parsed in future TRASHcan runs.
Repair GhidraMCP routing before the next sample-backed malware report	Medium	Current MCP returned OpenCTI HTML, preventing required Ghidra-backed decompilation.
Prefer memory capture for packed miner samples	Medium	XMRig signatures and config are often visible after unpacking in memory even when disk strings are weak.

18. References and Refresh Notes

- Local submitted archive: /home/lost0x01/internal-secops-portal/data/uploads/20260617_183712_464370/af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572.7z
- TRASHcan analysis draft: /home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a/analysis.md
- TRASHcan summary: /home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a/summary.json
- TRASHcan behavior summary: /home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a/behavior_summary.json
- TRASHcan static triage: /home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a/static_triage.json

- TRASHcan generated YARA: /home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a/rule.yar
- TRASHcan generated Sigma: /home/lost0x01/internal-secops-portal/data/sandbox-runs/2026-06-17_200129_af421881786a/sigma_behavior.yml
- Public Triage report: <https://tria.ge/230222-bpdrpabb9s>
- MalwareBazaar sample page: <https://bazaar.abuse.ch/sample/af421881786af65cf89b28d2a88d37658625f21f9644cf298c438267c7c92572/> (browser/API access was blocked during this run; search result snippets were used for correlation only)
- Gridinsoft family context: <https://gridinsoft.com/xmrig>

Refresh notes for future analysis:

- Re-query MalwareBazaar with an authorized API key to confirm current tags, first/last seen timestamps, reporter tags, and third-party sandbox links.
- Run a memory-first detonation profile that guarantees Sysmon/process-tree capture and dumps unpacked memory regions for YARA/config extraction.
- Repair or repoint GhidraMCP so decompilation can cite concrete function names, xrefs, and renamed symbols instead of fallback radare2/capa evidence.
- If production telemetry finds pool.hashvault.pro or 45.76.89.70 for this sample, enrich with passive DNS/WHOIS/ASN and add first-seen/last-seen observations to the IOC table.